HACKER WOMEN COUNCIL

Tecnología · Mujeres · Impacto Global — Ethical Hacking



Nombre completo:	Nelly Guadalupe Lara Hernández
Curso / Programa:	Hacker Women Council · Ethical Hacking
Fecha:	30 de agosto de 2026

Nota metodológica

Este documento desarrolla los siete puntos solicitados en la actividad, aplicando el rol de un equipo profesional de Ethical Hacking / Penetration Testing sobre el caso de estudio “Aurora Market”: una plataforma de comercio electrónico mexicana que reportó un posible incidente de exposición de información entre cuentas de clientes y contrató una evaluación formal de seguridad.

1. Objetivo del pentest

A partir del escenario de Aurora Market, se establecen los siguientes tres objetivos concretos para la evaluación de seguridad:

- **Identificar y validar vulnerabilidades explotables en la aplicación web de Aurora Market,** con especial énfasis en fallas de control de acceso y autorización (como el caso reportado por un cliente que visualizó información de otra cuenta), inyección, autenticación y gestión de sesiones, que puedan comprometer la confidencialidad de los datos personales y de pedidos de los clientes.
- **Determinar el riesgo real de negocio asociado a cada hallazgo,** evaluando su impacto potencial sobre la confidencialidad de la información de clientes, la integridad de pedidos e inventario, la disponibilidad de la plataforma y la reputación y el cumplimiento normativo de Aurora Market, priorizando los hallazgos según su severidad y probabilidad de explotación.
- **Entregar un informe técnico y ejecutivo claro y accionable,** con evidencia de cada vulnerabilidad y recomendaciones de remediación priorizadas, que permita a los equipos de desarrollo y a la dirección de Aurora Market tomar decisiones informadas para fortalecer la seguridad de la plataforma antes de que un atacante real explote estas debilidades.

> **Tip aplicado**
> Estos objetivos no buscan únicamente “encontrar fallas”, sino responder a la pregunta que motivó el proyecto: ¿qué tan segura es realmente la aplicación de Aurora Market?, entregando información útil para reducir el riesgo del negocio.

2. Alcance

El alcance delimita con precisión los sistemas que serán evaluados y aquellos que quedan explícitamente excluidos, conforme a la autorización otorgada por Aurora Market.

✓ SÍ SE EVALUARÁ	✕ FUERA DEL ALCANCE
• Aplicación web pública de Aurora Market: registro de cuentas, inicio de sesión, catálogo y búsqueda de productos, carrito de compras, checkout y seguimiento de pedidos. • Panel administrativo (backoffice) utilizado por el personal interno para gestionar productos, usuarios y pedidos. • APIs y servicios backend que dan soporte a la aplicación web (autenticación,	• Redes sociales oficiales de Aurora Market y las cuentas asociadas a ellas. • Equipos personales y dispositivos de los empleados de Aurora Market. • Cuentas y servidores de correo corporativo del personal. • Proveedores externos e infraestructura de terceros no autorizada explícitamente (pasarelas de pago, hosting, mensajería, etc.).

sesiones, consulta y gestión de datos de clientes y pedidos). • Mecanismos de autenticación, autorización y control de acceso entre los distintos tipos de usuario (clientes y personal interno). • Escenario puntual reportado por un cliente: posible exposición de información perteneciente a otra cuenta.	• Cualquier sistema o subdominio no incluido por escrito en el alcance, así como pruebas de denegación de servicio (DoS/DDoS).

3. Autorización y condiciones

Antes de iniciar cualquier prueba técnica, deben quedar formalmente definidos los siguientes permisos y condiciones entre el equipo de Ethical Hacking y Aurora Market:

PERMISOS REQUERIDOS	CONDICIONES ACORDADAS
• Autorización formal por escrito (carta de autorización / Rules of Engagement) firmada por un representante de Aurora Market con potestad para autorizarla. • Acuerdo de confidencialidad (NDA) firmado entre ambas partes. • Credenciales de prueba (cuentas de cliente y, de ser posible, de personal interno) creadas específicamente para el pentest, sin usar datos ni cuentas reales. • Punto de contacto técnico de Aurora Market disponible durante la ejecución para escalar dudas o incidentes. • Canal y protocolo definidos para reportar de inmediato cualquier hallazgo crítico, sin esperar al informe final.	• Las pruebas se realizan únicamente sobre la aplicación web autorizada; queda prohibido atacar redes sociales, equipos personales, correos o proveedores externos. • No se ejecutarán acciones que interrumpan deliberadamente la plataforma ni que afecten información real de clientes. • Las pruebas técnicas se ejecutarán en horarios de menor actividad, previamente acordados con Aurora Market. • Toda vulnerabilidad crítica se comunicará de inmediato al equipo técnico, de forma paralela al informe final. • La colaboración se basa en confianza, transparencia y comunicación constante entre ambos equipos durante todo el proyecto.

4. Tipo de pentest

Tipo de pentest elegido: Gray-box (caja gris)

☐ BLACK-BOX	☑ GRAY-BOX	☐ WHITE-BOX
El evaluador no tiene conocimiento previo de la infraestructura, código o configuraciones.	*El evaluador tiene información parcial, como credenciales o datos de la aplicación, pero no conoce todos los detalles internos.*	*El evaluador tiene conocimiento completo de la infraestructura, el código fuente y configuraciones.*

Justificación de la elección

Según la información compartida por Aurora Market en la etapa de planificación, el equipo evaluador no parte de cero, como ocurriría en un escenario black-box, ni cuenta tampoco con acceso completo al código fuente, la arquitectura y las configuraciones internas, como correspondería a un escenario white-box. Aurora Market entregó información parcial: se sabe que existe una aplicación web, una base de datos, mecanismos de autenticación y distintos tipos de usuario (clientes y personal interno), pero no se compartieron detalles técnicos completos sobre tecnologías, arquitectura ni código fuente.

Este nivel de conocimiento parcial, normalmente acompañado de credenciales de prueba para simular usuarios legítimos, corresponde exactamente a la definición de un pentest gray-box. Este enfoque es además el más adecuado para este caso concreto: permite evaluar tanto los riesgos que enfrentaría un atacante externo como los riesgos derivados de un posible abuso de privilegios o de fallas de control de acceso entre cuentas —que es justamente el tipo de incidente reportado por el cliente— sin necesidad de acceso al código fuente, y resulta más eficiente en tiempo que un enfoque black-box puro, ya que permite enfocar los esfuerzos en los módulos de negocio más relevantes (cuentas, pedidos y panel administrativo).

5. Planificación

Antes de iniciar la parte técnica, el equipo debe completar los siguientes elementos clave de planificación:

- **Objetivos:** confirmar y documentar por escrito los tres objetivos definidos en el punto 1 — identificar vulnerabilidades (en especial de control de acceso), evaluar su riesgo real para el negocio y entregar un informe con recomendaciones priorizadas.
- **Alcance:** delimitar por escrito los activos incluidos (aplicación web, panel administrativo y APIs asociadas) y excluidos (redes sociales, equipos personales, correo corporativo y proveedores externos), conforme al punto 2, y hacerlo firmar por Aurora Market.

- **Permisos y condiciones:** formalizar la autorización escrita, el NDA, las credenciales de prueba y las reglas de comportamiento (sin pruebas destructivas, sin afectar datos reales, horarios de menor actividad), conforme al punto 3.
- **Metodología a utilizar:** documentar el marco de referencia que guiará la evaluación —OWASP Web Security Testing Guide (WSTG) combinado con el PTES— definiendo las categorías de prueba aplicables a autenticación, control de acceso y gestión de pedidos.
- **Recopilación de información previa:** reunir toda la información entregada por Aurora Market (URLs autorizadas, credenciales de prueba, roles de usuario, contexto del incidente reportado) y realizar un reconocimiento pasivo (OSINT) del dominio autorizado.
- **Recursos necesarios:** definir el equipo y sus roles, el entorno y herramientas a usar (proxy de interceptación, escáneres de vulnerabilidades, herramientas de explotación manual, cuentas de prueba dedicadas) y el tiempo estimado por fase.
- **Programación del pentest:** establecer un cronograma con fechas de inicio y fin, ventanas horarias autorizadas de menor actividad, hitos de comunicación de avances y fecha de entrega del informe final.

6. Fases del pentest

A continuación se explica cómo se aplicaría cada fase metodológica al caso concreto de Aurora Market:

1. Reconocimiento: recopilar información pública y autorizada sobre la aplicación web —estructura del sitio, tecnologías utilizadas mediante fingerprinting no intrusivo, endpoints de la API, flujos de registro, inicio de sesión y checkout, y los roles de usuario visibles (cliente y personal)—. Se analiza también el contexto del incidente reportado (qué módulo estaba usando el cliente cuando observó datos de otra cuenta) para orientar la investigación hacia las áreas de mayor riesgo.
2. Análisis de vulnerabilidades: con las credenciales de prueba proporcionadas, mapear la aplicación y buscar activamente fallas, priorizando las de control de acceso (IDOR, escalación de privilegios horizontal entre clientes o vertical hacia el panel administrativo), inyección (SQL/NoSQL), gestión débil de sesiones y tokens, exposición de datos sensibles y configuraciones inseguras, combinando herramientas automatizadas (escáneres, proxy de interceptación) con pruebas manuales.
3. Explotación: validar de forma controlada y no destructiva las vulnerabilidades identificadas, confirmando si es posible acceder a información de otra cuenta —replicando y determinando la causa raíz del incidente reportado por el cliente—, evitando en todo momento modificar, eliminar o exponer datos reales, y documentando evidencia (capturas, solicitudes y respuestas) de cada hallazgo confirmado.
4. Post-explotación: determinar el alcance real del impacto de cada vulnerabilidad confirmada —qué información pudo quedar expuesta (datos personales, historial de compras), si es posible escalar desde una cuenta de cliente hacia el panel administrativo, y qué tan persistente o replicable sería un acceso no autorizado—, siempre dentro del entorno autorizado y sin afectar la operación del negocio.
5. Informe: documentar cada hallazgo con descripción técnica, evidencia, nivel de riesgo (por ejemplo con CVSS), módulos afectados y recomendaciones de remediación específicas. Se entrega un informe técnico

detallado para el equipo de desarrollo y un resumen ejecutivo para la dirección, incluyendo la explicación del incidente original que dio origen al proyecto y las medidas para prevenir casos similares.

7. Investigación

Metodología elegida:	OWASP Web Security Testing Guide (WSTG), complementada con el PTES

¿Por qué sería útil para este proyecto?

El OWASP WSTG es una metodología especializada y de referencia mundial para evaluar la seguridad de aplicaciones web, y cubre en detalle las categorías de prueba más relevantes para Aurora Market: autenticación, gestión de sesiones y, en particular, pruebas de autorización y control de acceso (como los defectos tipo IDOR), directamente aplicables al incidente reportado por el cliente que vio información de otra cuenta.

Al ser una metodología abierta, estructurada por categorías y ampliamente adoptada en la industria, permite al equipo cubrir sistemáticamente toda la superficie de la aplicación sin omitir áreas críticas, y facilita la comunicación de los resultados con el equipo de desarrollo de Aurora Market, que probablemente también la conoce o puede consultarla. Complementarla con el PTES (Penetration Testing Execution Standard) aporta una estructura clara para las fases de planificación, recolección de información, modelado de amenazas y generación de informes, alineándose con la interacción real que tendrá el equipo con Aurora Market en materia de autorización, comunicación y entrega de resultados.